Architectures, Services and Attacks

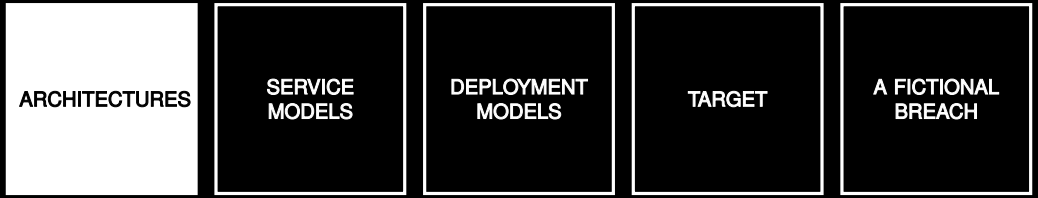
Joseph Maguire

Enterprise Cyber Security

Overview

- How enterprise **architectures** evolved, and the security concerns each era left behind.
- Cloud **service models** (IaaS, PaaS, SaaS) and **deployment models** (public, private, community, hybrid).
- The 2013 **Target** breach: how a contractor's access became 40 million stolen cards.
- A **fictional breach**: seven attacks, and what each one looks like in a server's logs.


ARCHITECTURES
SERVICE MODELS
DEPLOYMENT MODELS
TARGET
A FICTIONAL BREACH

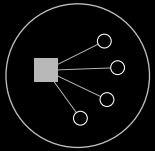

ARCHITECTURES
SERVICE MODELS
DEPLOYMENT MODELS
TARGET
A FICTIONAL BREACH

Enterprise Architecture

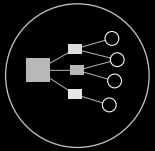
Enterprise Architecture

Overview

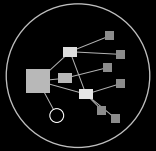
- Enterprises have made **significant investment** in system architectures, some over a number of decades.
- Many enterprises still rely on **prior architectures** and systems in their present systems and processes.
- It is important to appreciate the **primary security concerns** of each era, and the **legacy concerns** each era leaves behind.



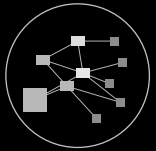
Mainframe
Era



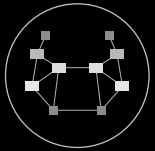
Minicomputer
Era



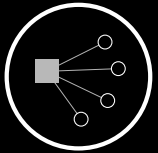
Distributed/PC
Era



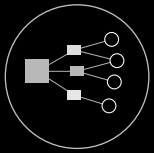
Client-server
Era



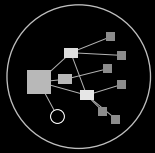
Networked
Era



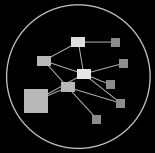
Mainframe Era



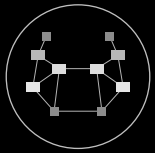
Minicomputer Era



Distributed/PC Era



Client-server Era



Networked Era

Mainframe era (1950s to 1970s)

- Few mainstream suppliers (IBM, ICL, Amdahl, Burroughs, Univac, Honeywell, Fujitsu).
- Simple architecture with **centralised, tight control** and low autonomy.
- Back-office automation and transaction processing, relying on **dumb terminals**.
- Very high costs, and the emergence of siloed applications.
- Access meant **resource access**, not physical access: queuing with punched cards, later read remotely over cable.

“It had all the glamour and excitement of dropping one’s clothes off at a laundromat.”

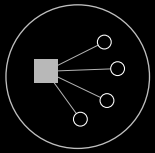
Fernando Corbató

Mainframes today

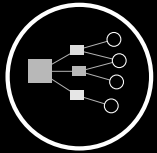
Case study: New Jersey, 2020

- **What happened**: in April 2020, COVID-19 drove a 1,600% rise in New Jersey's unemployment claims, over 206,000 in one week, and the state's claims system struggled to keep up.
- The system ran on **decades-old mainframe** software written in COBOL.
- The governor publicly appealed for **volunteers who could program in COBOL**.
- A mainframe-era system still carried a critical public service, and its **availability** depended on skills that had almost gone.

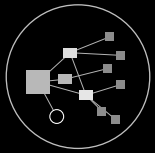
StateScoop (2020) New Jersey needs COBOL coders to fix ailing unemployment system.
https://statescoop.com/coronavirus-new-jersey-needs-cobol-coders-unemployment/



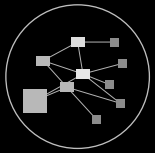
Mainframe
Era



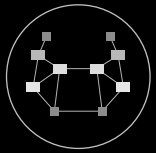
Minicomputer
Era



Distributed/PC
Era



Client-server
Era



Networked
Era

Minicomputer era (1970s to 1980s)

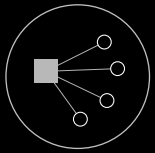
- More suppliers (IBM, ICL, DEC, NCR), architecture still simple with dumb terminals and transaction processing.
- Silo applications: **islands of automation**, mismatched data and mismatched strategy.
- **Stovepipe systems**: built for one purpose and one set of users, with the technology in fashion at the time.
- No real thought for integration: logistics and HR each have their own systems that do not talk to each other.

Today’s stovepipes

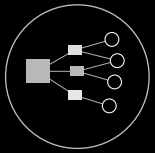
Case study: shadow IT

- **What happens**: staff adopt devices and services that the organisation does not know about, usually because the approved tools do not meet their needs. The NCSC calls this **shadow IT**.
- Examples: personal cloud storage for sharing files, personal messaging apps, servers set up by staff, unapproved AI chatbots.
- Like a stovepipe, each solves one team’s problem, and the enterprise loses a **coherent view** of its data.
- The NCSC’s advice: it is rarely malicious, so meet the underlying need and make it easy to ask.

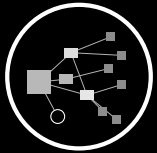
NCSC (2023) Shadow IT: how to manage the risks.
https://www.ncsc.gov.uk/guidance/shadow-it



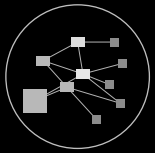
Mainframe
Era



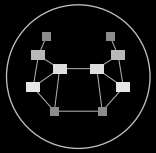
Minicomputer
Era



**Distributed/PC
Era**



Client-server
Era



Networked
Era

Distributed/PC era (1980s to 1990s)

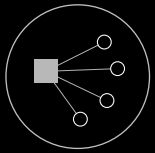
- A burgeoning market for personal computers from many suppliers.
- Complex architectures with far more **autonomy**, down to the departmental level.
- Integration remains poor, and harder still with emerging technologies (voice, data).

WannaCry

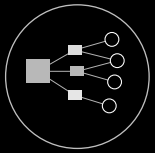
Case study: the NHS, May 2017

- **What happened**: on 12 May 2017, WannaCry ransomware spread across networks worldwide, encrypting files and demanding payment, and reached NHS organisations in England.
- At least **81 of 236** NHS trusts were affected, and 595 GP practices. An estimated **19,000** appointments were cancelled.
- The infected organisations had **unpatched or unsupported** Windows systems.
- The NAO found it was a relatively unsophisticated attack that **basic IT security** practice could have prevented.

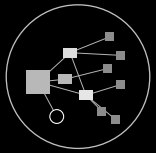
National Audit Office (2017) Investigation: WannaCry cyber attack and the NHS.
https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/



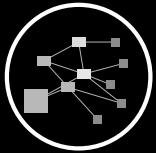
Mainframe
Era



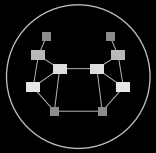
Minicomputer
Era



Distributed/PC
Era



Client-server Era



Networked
Era

Client-server era (1990s)

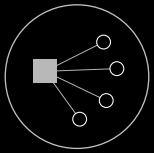
- A wealth of suppliers, but choice constrained by proprietary versus open standards.
- The **Internet** standardised communication, and became a greater interest and challenge for the enterprise.
- Business units had considerable autonomy while **more and more data** was captured.

SolarWinds

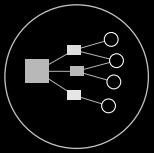
Case study: Orion, 2020

- **What happened**: attackers broke into SolarWinds and hid malicious code (SUNBURST) in updates to its Orion software, released between March and June 2020. Customers installed it themselves.
- Orion is **network management** software: it needs wide, privileged access to the systems it watches.
- About **18,000** customers installed the affected updates, but fewer than 100 were actually hacked through them.
- In December 2020, CISA ordered US federal agencies to **disconnect or power down** Orion products.

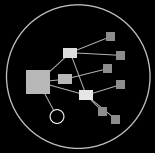
SolarWinds (2021) An investigative update of the cyberattack. CISA (2020) Emergency Directive 21-01.
https://www.solarwinds.com/blog/an-investigative-update-of-the-cyberattack
https://www.cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise-closed



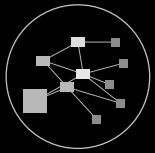
Mainframe
Era



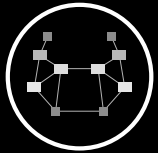
Minicomputer
Era



Distributed/PC
Era



Client-server
Era



**Networked
Era**

Networked era (2000s)

- Systems are **connected together** to achieve business processes.
- Suppliers offer more **outsourcing**, sometimes to meet legal and compliance needs.
- Cheaper, more capable hardware lets business units capture data and draw on resources elsewhere in the enterprise.

Cloud era

- Enterprises **rent resources** from providers, running applications “in the cloud”.
- Little up-front investment (not always), and the ability to **scale** up and down with demand.
- **Service Level Agreements** (SLAs) give contractual expectations and flexibility in scale.
- Challenging competencies can be **outsourced**, with legal and location issues attached.

Beyond the perimeter
Case study: Google BeyondCorp

- **What happened**: Google stopped treating its internal network as trusted. Staff reach applications according to who they are and the state of their device, not where they connect from. Google described the approach in 2014.
- The perimeter model trusts whatever is inside the corporate network. Once it is breached, an attacker has relatively easy access to everything inside.
- This idea is now known as **zero trust**.
- Remote contractors and cloud services sit **outside** any perimeter anyway.

Ward and Beyer (2014) BeyondCorp: a new approach to enterprise security. ;login: 39(6).
https://www.usenix.org/publications/login/dec14/ward

Dependency

Case study: CrowdStrike, July 2024

- **What happened**: on 19 July 2024, a faulty update to CrowdStrike's Falcon security software crashed the Windows computers that received it. It was withdrawn 78 minutes later.
- About **8.5 million** devices were affected, including airlines, hospitals and banks, and many had to be repaired by hand.
- **Not a cyberattack**, but the same effect: lost availability, from depending on one supplier's software on every machine.
- Security tools are part of the **attack surface**: what can update every computer at once can break every computer at once.

CrowdStrike (2024) Falcon content update preliminary post incident report. Microsoft (2024) Helping our customers through the CrowdStrike outage.
https://www.crowdstrike.com/en-us/blog/falcon-content-update-preliminary-post-incident-report/
https://blogs.microsoft.com/blog/2024/07/20/helping-our-customers-through-the-crowdstrike-outage/

Every era is still here

Legacy concerns

- Enterprises rarely replace one era with the next. They **accumulate** them.
- A retailer can run a central database server (**client-server**), tills and back-office PCs in every store (**distributed**), contractors connecting remotely (**networked**), and an online shop hosted by a provider (**cloud**).
- Each layer brings its own concerns, and the joins between layers bring more.
- In 2013, **Target** was exactly this kind of retailer.

Legacy debt

Why old systems stay

- **What happened**: in 2019, the US Government Accountability Office reviewed ten critical federal legacy systems. They were **8 to 51 years old**, some written in COBOL, and one had 168 high or critical security vulnerabilities.
- Old systems stay because replacing them is **costly and risky**, and they still work.
- About **80%** of US federal IT spending went on operating and maintaining existing systems.
- Legacy systems are harder to **patch**, **log** and **monitor**, and fewer people understand them.

US GAO (2019) Information technology: agencies need to develop modernization plans for critical legacy systems. GAO-19-471. https://www.gao.gov/products/gao-19-471


ARCHITECTURES
SERVICE MODELS
DEPLOYMENT MODELS
TARGET
A FICTIONAL BREACH

Cloud Computing

“It starts with the premise that the data services and architecture should be on servers. We call it cloud computing, they should be in a “cloud” somewhere. And that if you have the right kind of browser or the right kind of access, it doesn’t matter whether you have a PC or a Mac or a mobile phone or a BlackBerry or what have you, or new devices still to be developed, you can get access to the cloud.”

Eric Schmidt, Search Engine Strategies, 2006

Cloud Computing
Characteristics

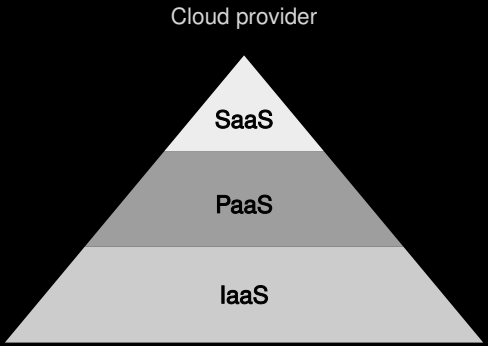
- **On-demand self-service**: servers and storage provisioned without human interaction.
- **Broad network access**: standardised access for thin and thick clients.
- **Resource pooling**: multi-tenant access to shared infrastructure.
- **Rapid elasticity**: almost unlimited resources for short bursts.
- **Measured service**: usage monitored, reported and billed.

Mell and Grance (2011) The NIST Definition of Cloud Computing, NIST SP 800-145.
https://csrc.nist.gov/pubs/sp/800/145/final

Service Models

Service models

Who works at each level



Infrastructure as a Service

- The most basic service model: **processing, storage and network** delivered as a service.
- Conceived as **virtual machines** the enterprise manages, with no real control of the physical infrastructure.
- The enterprise is **close to the metal**: more control than other models, and more support and responsibility costs.

Platform as a Service

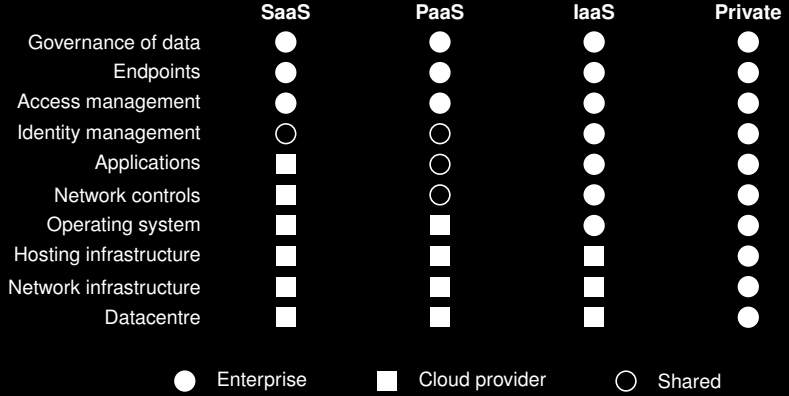
- Enterprises deploy applications on a **platform** built on the infrastructure.
- Applications use the languages, libraries, services and frameworks the **provider supports**.
- No real insight into the infrastructure beneath the platform, but **control over the applications** deployed and their configuration.

Software as a Service

- Enterprises are granted access to **applications** run by the provider.
- Accessed from thin clients, or programmatically through an interface.
- **No sense** of the underlying infrastructure, and little control over platform or application.

Responsibility

Who is responsible for each element



The customer's side of the line

Case study: Capital One, 2019

- **What happened**: in 2019, an attacker exploited a **misconfigured web application firewall** in Capital One's cloud environment and copied data stored there.
- About **106 million** people were affected: around 100 million in the US and 6 million in Canada.
- The misconfiguration was in Capital One's own set-up: the **customer's side** of the responsibility line.
- In 2020, the US regulator (OCC) fined Capital One **$80 million**, citing failures to assess risk before moving significant operations to the public cloud.

Al Jazeera (2019) Capital One says 106 million people's information hacked. https://www.aljazeera.com/economy/2019/7/30/capital-one-says-106-million-peoples-information-hacked

OCC (2020) News release 2020-101. https://www.occ.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html

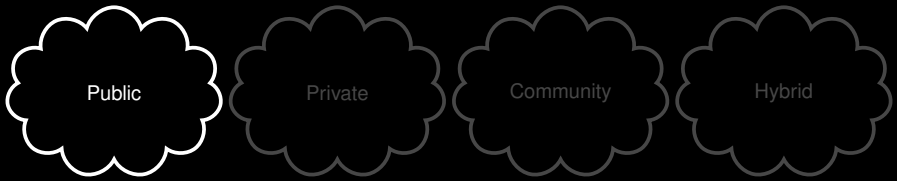

ARCHITECTURES
SERVICE MODELS
DEPLOYMENT MODELS
TARGET
A FICTIONAL BREACH

Deployment Models

Deployment models

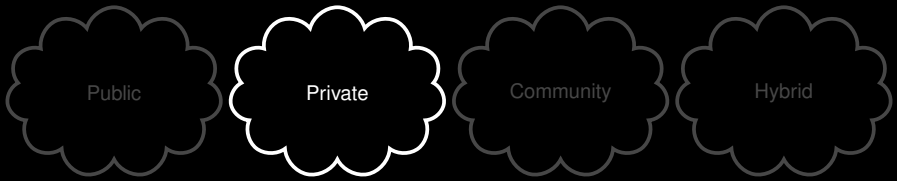
Three questions define them

- **Where** are the physical servers and other resources, and who provides them?
- **Who controls** the virtualisation software that creates and manages the virtual machines?
- **Who configures, supports and maintains** the infrastructure: who is responsible when something goes wrong?


Public
Private
Community
Hybrid

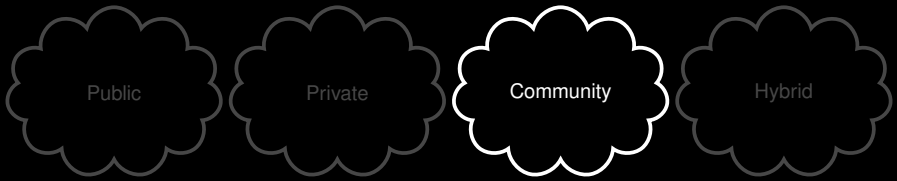
Public cloud

- Infrastructure managed by a provider and **open to the public**.
- The provider may be a business, a government, a research organisation, or a mixture.
- Infrastructure sits on the **provider's premises**, and configuration and support are the provider's.


Public
Private
Community
Hybrid

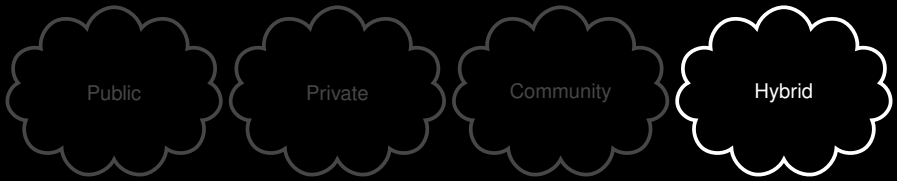
Private cloud

- Infrastructure for the **exclusive use** of one enterprise and its business units.
- Managed internally, by a third party, or a mixture of both.
- Located **on or off premises**, whoever manages it.


Public
Private
Community
Hybrid

Community cloud

- Infrastructure for the exclusive use of a **community of organisations** with a shared concern.
- The shared concern may be security requirements, compliance, or policy.
- Managed by one or more members or an external party, on or off premises.


Public
Private
Community
Hybrid

Hybrid cloud

- A **composition** of two or more private, community or public infrastructures.
- Joined by standard or proprietary technology, while each remains an independent entity.
- **Cloud bursting**: a private cloud draws on public cloud when demand increases.

Who holds the logs?

From cloud to evidence

Model	Logs the enterprise can see
On-premises, IaaS	The operating system's own logs: logins, `sudo`, services, scheduled jobs.
PaaS	Application and platform logs the provider chooses to expose, with little or nothing from the operating system.
SaaS	Audit logs of the provider's design: who signed in, what they changed.

Providers may not log what matters to you. Agree what is logged, and who can read it, before an incident.

Incident response in the cloud

- Complexity makes it hard to respond, especially without a clear view of **which data and services are where**.
- Providers may be **reluctant to share** data on vulnerabilities or detailed events.
- Response must be **quick** and **documented**: it may end up in legal proceedings.
- What evidence you have depends on the service model.

Architectures, Services and Attacks

Joseph Maguire

Enterprise Cyber Security